

CYBE 435

Computer Incident Response

Lecture 1: Course Overview

Consider the following incident from July 2017

- Equifax is one of three major credit reporting services
- Attackers gained access to Equifax's credit database using a known Apache vulnerable
- A patch had been available for several months, and Equifax did not install the patch in time.
- Hackers gained access to personal data for ~147 million people
 - Social Security Numbers
 - Birth Dates
 - Credit Card numbers

How the situation was made worse by poor Incident Response

- Poor management of security updates
 - A patch had been available since March 2017 but not installed until the breach was discovered in July
- Delayed Detection
 - Hackers had access for 76 days before they were detected
 - Logs were not systematically monitored
- Ineffective Containment
 - Even after the breach was detected, IT was slow to cut off access
- Poor communication
 - The breach was not publicly announced until September 2017

Costs associated with the Equifax Breach

- **Financial:** Estimated \$1.4 billion in costs (settlements, legal fees, security upgrades)
- **Legal/Regulatory:** \$700M FTC settlement (largest ever for a data breach at the time)
- **Reputational:** Severe damage to Equifax's credibility as a consumer credit reporting agency
- **Leadership fallout:** CEO, CIO, and CSO all resigned.

Consider the following incident from 2018

- Tesla's AWS data storage site was breached by hackers
- Cloud security firm RedLock discovered that Tesla's Kubernetes administration console on AWS was left unsecured with no password
- Attackers exploited this and installed data mining malware on the AWS site
- Attackers did not gain access to sensitive customer information

What Tesla did right in this case

- Rapid Detection
 - RedLock quickly detected and reported unusual activity
- Immediate Containment
 - Tesla's security team immediately locked down the exposed console, revoked access privileges, and removed the malware
- Transparency & Clear Communication
 - Tesla publicly disclosed the incident and credited RedLock
- Used incident to improve security
 - Tesla established a bounty program
- Consequence: You probably have heard of the Equifax breach, but may not have heard of this one.

Six Phases of Incident Response (NIST & SANS)

- Preparation
- Identification
- Containment
- Eradication
- Recovery
- Follow up with Lessons Learned

CPE 435 – Computer Incident Response

- Meeting Times: Tuesday/Thursday 9:30-10:45am
- Instructor: Professor Brian Woerner
 - 254 AER
 - brian.woerner@mail.wvu.edu (mix forwards to this address)
- Office Hours:
 - TR 11am-12 noon or by appointment
- Prerequisite: CPE 310
- No required textbook. Some recommended references are given on the syllabus

Tenative Class Schedule

- Week 1: Introduction to Incident Response
- Week 2: Preparation and Incident Management Planning
- Week 3: Detection and Analysis
- Week 4: Threat Intelligence: Logs and Indicators
- Week 5: Malware Detection and Firewalls
- Week 6: Containment Strategies
- Week 7: Eradication and Recovery
- Week 8: Disk and File Forensics
- Week 9: Evidence Collection and Handling
- Week 10: Post Incident Activity
- Week 11: Reverse Engineering
- Week 12: Reverse Engineering
- Week 13: Authentication Phishing and Credential Theft
- Week 14: Case Studies
- Week 15: Applying Incident Response techniques: Final Project Presentations

Assignments and Grading

5 Quizzes (5 % each)	25%
4 Homework/Lab Exercises (7.5% each)	30%
NCL Competition (pre-season 10% + individual game 10% + team game 5%):	25%
Final Project & Report	20%
TOTAL	100 %